Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

PRINCIPLES OF INFORMATION SECURITY

Who are you, and what may you do



Day 5 - Morning

Running case: Taxila College, a fictional college

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

Today

Who may sign in, what they may do, and a server that runs only what it needs.

- Authentication, authorisation and accounting - 35 min
- Factors and multi-factor sign-in - 30 min
- Access-control models - 30 min
- Least privilege and separation of duties - 30 min
- Hardening a baseline - 30 min



Today serves two outcomes

LO1 Explain the fundamentals of information security.

LO2 Discuss the key characteristics of cryptography and cryptographic systems.

LO3 Analyze the principles of encryption, decryption, hashing, and data integrity.

LO4 Outline the process of ensuring digital security.

LO5 Describe the fundamentals of threats and countermeasures.

LO6 Explain the fundamentals and process of business continuity planning.

Where we start

RECALL

On Day 1 you met five properties: confidentiality, integrity, availability, authenticity and accountability.

- A stored password is kept as a **salted digest**, not as plaintext
- A **signature** proves which person acted
- Today: three **processes**, which are not the five properties

Properties say what must be true. Processes are steps a system runs.

The changed grade

- A final grade in the SIS was **higher** than the lecturer had entered
- The SIS showed the new grade
- It did **not** show who changed it, or when

Can we prove who changed it?

T TAXILA

Every grade change attributable to a named person, and approved by a second person.



REGISTRAR

Can we prove who changed it?

The Registrar, on the fifth day of your placement.

CONCEPT 1

Authentication, authorisation and accounting

The changed grade had no departure log, so no one could be held to account.

TRY IT FIRST

Three gates: who you are, what you may do, what you did.

35 min

Demonstration: three gates

1. Send lecturer01 to enter a grade
2. Send student01 to change a grade
3. Try a wrong password for lecturer01
4. Switch off the accounting gate and repeat

Each gate can fail on its own.

Three processes, in order

Gate 1

Authentication

Who are you? The system checks a claimed identity.

The SIS checks `lecturer01`'s password.

Gate 2

Authorisation

What may you do? The system looks up what this identity is allowed.

Enter grades for own modules only.

Gate 3

Accounting

What did you do? The system records who, what and when.

One log line per grade change.

Together they are called **AAA**.

Processes are not properties

Properties (Day 1)

- **Authenticity**: the person or data is genuine
- **Accountability**: an action can be traced to a person
- Say what must be **true**

Processes (today)

- **Authentication**: the step that checks identity
- **Accounting**: the step that records each action
- Are steps a system **runs**

Accounting is the process that produces the accountability property.

The passport desk, the gate, the log

YOU ALREADY KNOW THIS

At an airport, the passport desk checks you are the person in the passport. The boarding gate checks your pass is for this flight. The airline logs who boarded.

MAPPING

the passport desk = authentication · **the boarding gate** = authorisation · **the departure log** = accounting

T TAXILA

The changed grade had no departure log, so no one could be held to account.

× COMMON MISTAKE

Authentication is the same as authenticity.

Authentication is a process; authenticity is a property.

CONCEPT 2

Factors and multi-factor sign-in

Staff reuse passwords, so the SIS needs a second factor.

TRY IT FIRST

Stack factors so a stolen password alone fails.

30 min

Three kinds of factor

RECALL

A stored password is kept as a salted digest, not as plaintext.

- **Something you know**: a password, a PIN
- **Something you have**: a phone app's code, a security key
- **Something you are**: a fingerprint, your face
- **Multi-factor authentication (MFA)**: two or more kinds

Two passwords are still one factor.

Demonstration: stack the factors

1. Replay the leaked list with the password only
2. Read the sign-in log
3. Add the phone code and replay
4. Add the fingerprint instead

A stolen password alone is not enough.

Credential stuffing, seen in the log

Password and a second factor

The reused password is right, but the list holds no phone. The sign-in stops at the second factor.

× Password only

Leaked pairs from another site are replayed. Wherever a person reused the password, it works.

Salting did not help; the password itself was right.

*Credential stuffing **replays** leaked pairs. It fails against a second factor.*

A key and a code

YOU ALREADY KNOW THIS

Some office doors need a key and a code typed on a keypad. A found key alone, or a seen code alone, opens nothing.

MAPPING

the key = something you have · **the code =** something you know · **needing both =** multi-factor authentication

T TAXILA

Staff reuse passwords, so the SIS needs a second factor.

CONCEPT 3

Access-control models

A lecturer role sees grades; a student role sees only its own record.

TRY IT FIRST

Move a user between roles and watch permissions change.

30 min

Demonstration: who opens what

1. Discretionary: lecturer01 shares a marks folder
2. Mandatory: lecturer01 tries to share the exam paper
3. Role-based: assign student01 to the lecturer role
4. Move student01 back to the student role

In role-based control, the permissions belong to the role.

Three access-control models

DAC

Discretionary

The owner of each resource decides who may use it.

Flexible, but access spreads.

MAC

Mandatory

System-set labels that users cannot override.

Strict and consistent, but rigid.

RBAC

Role-based

Permissions go to roles; people are assigned to roles.

Easy for many people; review the roles.

This MAC is mandatory access control, not the MAC inside HMAC.

Doors a job title opens

YOU ALREADY KNOW THIS

Three buildings: an owner lends keys; a government sets clearances; a job title opens certain doors.

MAPPING

the owner lending keys = DAC · **the clearance =** MAC · **the doors a job title opens =** the permissions a role carries in RBAC

T TAXILA

A lecturer role sees grades; a student role sees only its own record.

CONCEPT 4

Least privilege and separation of duties

A grade change needs a named editor and a second approver.

TRY IT FIRST

An over-privileged account, then least privilege, and the blast radius.

30 min

Demonstration: blast radius

1. Give lecturer01 one account for everything
2. Then every module, then own modules only
3. Suppose the password leaks at each setting
4. Add the Registrar's approval for released grades

The smaller the privilege, the smaller the blast radius.

Two limits that work together

Least privilege

- The **minimum** each account needs
- For **no longer** than needed
- Limits how far one account reaches

Separation of duties

- A **second person** approves a sensitive action
- No one person finishes it alone
- Limits what one person can do

A released grade changes only with the Registrar's approval.

A key-card for your floor only

YOU ALREADY KNOW THIS

A hotel key-card opens only your floor, and only for your stay. A refund needs the manager's approval.

MAPPING

your floor only = least privilege · **needing a manager to approve a refund** = separation of duties

T TAXILA

A grade change needs a named editor and a second approver.

× COMMON MISTAKE

Least privilege is about distrusting staff.

It is about containing the damage when a credential is stolen.

CONCEPT 5

Hardening a baseline

The Head of IT's audit found services nobody used on the SIS server.

TRY IT FIRST

A server whose attack surface shrinks as you harden it.

30 min

Demonstration: harden the server

1. Turn off the three unused services
2. Tighten the file every account can change
3. Apply the patches; remove the spare account
4. Turn on logging and read what changes

Each service turned off shrinks the attack surface.

Five areas of hardening

- **Users and groups**: only the accounts needed
- **File permissions**: each file open only to who needs it
- **Unused services and open ports**: close them
- **Patching**: fix known weaknesses
- **Logging**: record what happens

Much of hardening is turning things off, not buying a product.

Close the windows you never use

YOU ALREADY KNOW THIS

Before a long trip you close the windows you never use. You do not buy new locks; you just close them.

MAPPING

an unused open window = an unused running service · **closing it =** hardening

T TAXILA

The Head of IT's audit found services nobody used on the SIS server.

Common mistakes

× COMMON MISTAKE

Authentication is the same as authenticity.

Authentication is a process; authenticity is a property.

× COMMON MISTAKE

The three processes are the five properties.

They are separate lists taught on different days.

× COMMON MISTAKE

Least privilege is about distrusting staff.

It is about containing the damage when a credential is stolen.

Back to the changed grade

Which of the three processes failed when the grade changed, and which two controls from today would have stopped or traced it?

Before the next day

READ	**Security in Computing, sections 2.1 and 2.2** Authentication and access control; then section 5.1 for hardening.
PRACTICE	**A tea estate's payroll office** Practice question 5: the three processes, access-control models, one shared computer.
TASK	**Form your group of four** Agree the four roles for the group exercise. *Pack 5 follows this afternoon's lab.*

Questions & Discussion

This afternoon: audit your own baseline, fix your findings, and design least-privilege roles.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision f41255c